

Table of Contents

Cisco Secure Workload — CSA Cloud Controls Matrix v4.0 (CCM)

Reference Design | Multicloud and Hybrid Workload Security

Version: 1.0

Standard: CSA Cloud Controls Matrix (CCM) v4.0

Use Case: CCM-based assessments (including CSA STAR readiness), multicloud / hybrid IaaS and PaaS, shared responsibility alignment with ISO 27001, NIST, PCI DSS, and SOC 2 mappings

Reader's Guide

Who this is for. Cloud security architects, GRC teams using CSA CCM for gap analysis or STAR certification preparation, and operations teams implementing compensating technical controls on workloads (VMs, containers, and connected services) spanning public cloud and data center.

Questions this reference design helps you answer:

- For **IAM** and **IVS** (segmentation), can I show application-aware, deny-by-default network enforcement with identity context—not only cloud perimeter controls?
- For **AIS** (application and interface security), can I map real dependencies between tiers and APIs before locking interfaces?
- For **DSP** (data security and privacy lifecycle), can I document and control flows to sensitive tiers and demonstrate isolation between workloads with different data classes?
- For **LOG** (logging and monitoring), can I ship workload-level flow and process telemetry into the enterprise SIEM with retention suitable for investigations?
- For **TVM**, can I prioritize CVE remediation using exposure and east-west reachability, not only scanner output?
- For **BCR** and **CCC**, how does CSW support validation of recovery and change baselines without replacing formal BCM or ITSM?

What you'll need. A CCM control scope (which domains apply to which service layers per CSA shared responsibility), cloud account inventory, tagging standards, SIEM onboarding reference designs, and agreement on **in-scope workloads** (subscriptions, VPCs/VNets, projects).

Where to start. Section 2 for domain-to-capability orientation; sections 3–6 for deployment; sections 7–9 for policy and evidence aligned to **IVS**, **LOG**, **IAM**, **AIS**, and **DSP**; section 12 when packaging STAR or customer audit artifacts.

CSW primer — if you are new to Cisco Secure Workload

Cisco Secure Workload (CSW) is a **workload protection platform**. A lightweight **agent** on each server/VM/container observes processes and network flows; **cloud connectors** add AWS/Azure/GCP inventory where agents are not deployed.

CSW term	Meaning	Why compliance teams care
Scope	Logical boundary (CDE, PHI zone, CUI enclave)	Defines the systems you must prove are isolated
Label / filter	Tag or query assigning workloads to scopes	Automates scope membership — reduces drift
ADM	Application Dependency Mapping from observed traffic	Live network/data-flow diagram for assessors
Workspace	Policy container for one scope or application	Where allow/deny rules are authored
Monitor → Simulation → Enforce	Safe rollout sequence	Simulation = change-board evidence before blocking traffic
Denied Connections	Log of flows blocked by policy	Primary proof that enforcement operates

Console areas: Investigate (inventory, flows, vulns) · Defend/Segmentation (policy) · Manage (agents) · Platform (connectors) · Administration (audit log)

Read next: [Compliance evidence playbook](#) (full step-by-step) · [About CSW](#) (platform intro)

Universal evidence workflow

Execute these phases for **this framework's** compliance boundary. Map exports to control IDs in the **Reporting & Evidence** section below.

Phase	Goal	Key CSW actions	Typical duration
1 — Coverage	Every in-scope workload in CSW	Install agents/connectors ; apply compliance	Days 1–10

Phase	Goal	Key CSW actions	Typical duration
		labels; create scope	
2 — Baseline	Machine-generated flow map	Run ADM ≥ 2 weeks; export clusters; app-owner signoff	Days 11–28
3 — Policy	Designed isolation before enforce	Build workspace; Simulation mode; fix false positives	Days 29–45
4 — Operate	Continuous proof between audits	Enforce; quarterly export pack; ADM refresh every 90 days	Ongoing

Phase 1 checklist (coverage)

- ☐ In-scope host list reconciled to CSW Inventory (100% or documented exceptions)
- ☐ Labels applied: `compliance:<framework>`, `data:<classification>`, `env:<tier>`
- ☐ CSW scope created matching compliance boundary
- ☐ **Export:** inventory CSV + agent status screenshot

Phase 2 checklist (baseline)

- ☐ ADM running on compliance scope for full business cycle (≥ 2 weeks)
- ☐ Unexpected flows documented (shadow IT, vendor egress, scope creep)
- ☐ App owners signed cluster-to-application mapping
- ☐ **Export:** ADM diagram + flow samples with process context

Phase 3 checklist (policy)

- ☐ Default-deny posture defined for sensitive scope
- ☐ ADM-imported rules refined; Simulation run ≥ 1 week
- ☐ Change tickets for false-positive fixes; exception register updated
- ☐ **Export:** policy export + simulation report

Phase 4 checklist (operate)

- ☐ Enforcement enabled on pilot scope; negative test recorded in Denied Connections
- ☐ Quarterly pack: inventory, policy, denies, vulns, audit log (see playbook)
- ☐ SIEM integration verified (sample events)
- ☐ **Export:** enforcement screenshot + quarterly binder

What CSW evidence does not replace

Physical access, HR/training records, encryption key management, signed BAAs/vendor contracts, formal pen tests, and assessor attestation still require separate programmes. CSW

addresses the **workload-resident** slice: segmentation, flows, process context, vuln reachability, and change drift.

CSW effectiveness for this framework

- IVS-09 network security + DSP data isolation
- TVM reachability for cloud workload context
- STAR certification evidence support

Compared to manual programmes: static diagrams and annual firewall samples age immediately; CSW ties evidence to **live workload behaviour** and produces queryable exports on demand — supporting "operating effectively" language in PCI v4.0, SOC 2 CC7, and HIPAA risk analysis.

1. Overview

The CSA Cloud Controls Matrix v4.0 organizes **197 control objectives** across **17 domains**. CCM is deliberately **cloud-neutral** and is widely used to **harmonize** assessments with ISO/IEC 27001, NIST publications, PCI DSS, CIS Controls, and other frameworks—particularly in **CSA STAR** self-assessment and third-party certification programs.

Cisco Secure Workload (CSW) provides **workload-centric** visibility, micro-segmentation, vulnerability exposure analytics, and forensic telemetry. It addresses technical aspects of several CCM domains while remaining **out of scope** for purely organizational or HR-driven domains (notably parts of **HRS**). CSW complements CSP-native controls (security groups, WAF, CSPM, IAM policies) rather than replacing them.

1.1 CCM v4 Domains and CSW Relevance

Domain	Title	CSW relevance
A&A	Audit & Assurance	Supporting — artifacts for control testing samples; CSW is not the internal audit function
AIS	Application & Interface Security	Direct — dependency mapping, process-level visibility, constrained interfaces via policy
BCR	Business Continuity Management & Operational Resilience	Supporting — telemetry baselines and snapshots help validate recovered connectivity; BCM program remains organizational

Domain	Title	CSW relevance
CCC	Change Control & Configuration Management	Direct — software inventory changes, ADM drift versus approved flows
CEK	Cryptography, Encryption & Key Management	Supporting — detect cleartext paths; key vault operations are outside CSW
DCS	Datacenter Security	Limited — logical segmentation and workload monitoring where agents/connectors deploy; physical DC security is out of scope
DSP	Data Security & Privacy Lifecycle Management	Direct — data-flow mapping between tiers; isolation of sensitive workloads
GRC	Governance, Risk & Compliance	Supporting — continuous monitoring dashboards, exportable metrics for control KPIs
HRS	Human Resources	Out of scope — screening, training records, personnel policies
IAM	Identity & Access Management	Direct (technical) — identity-aware segmentation integrated with enterprise identity context where supported; IAM lifecycle is IAM-team owned
IPY	Interoperability & Portability	Out of scope — architectural portability decisions
IVS	Infrastructure & Virtualization Security	Direct — micro-segmentation, isolation, cloud/on-prem workload visibility
LOG	Logging and Monitoring	Direct — flow + process telemetry; SIEM

Domain	Title	CSW relevance
SEF	Security Incident Management, E-Discovery, & Cloud Forensics	integration Supporting (evidence) — incident timelines, scope of lateral movement
STA	Supply Chain Management, Transparency, and Accountability	Limited — workload artifact visibility; procurement SCRM is organizational
TVM	Threat & Vulnerability Management	Direct — CVE inventory, prioritization with reachability / EPSS-style context if available
UEM	Universal Endpoint Management	Limited — server/workload focus; mobile UEM is typically separate tooling

2. Pre-Deployment Checklist

- ☐ CSW tenancy matches data residency and contractual constraints for assessed cloud regions.
- ☐ All **in-scope** cloud accounts / subscriptions registered; read-only discovery roles documented in CCM evidence (IAM policies attached to CCM CCC / IAM folders).
- ☐ Network path from workloads and connectors to CSW management plane (typically HTTPS) allowed.
- ☐ Tag strategy defined: `environment`, `data_class`, `service_tier`, `ccm_scope`, `star_service_id`.
- ☐ Stakeholders: cloud platform engineering, security architecture, GRC lead, SOC.
- ☐ Initial posture: **monitoring** / **simulation** before production enforcement.

3. Phase 1 — Sensor and Connector Deployment (Days 1–7)

3.1 IaaS / VM-Based Workloads

```
# Linux agent example (package names vary by distro – use Cisco-
supplied packages for your OS)
sudo rpm -ivh tet-sensor-<version>.rpm
sudo systemctl enable --now tet-engine || sudo systemctl enable --now
csw-agent
```

Windows: deploy via approved packaging (SCCM / Intune / golden image) with automatic startup verification.

3.2 Cloud Connectors (AWS / Azure / GCP)

CSW UI → Platform → External Orchestrators

- Register each cloud account used by in-scope services
- Map resource tags → CSW labels (e.g., Confidentiality=HIGH → DSP-High scope)
- Enable optional flow telemetry sources supported for your CSP (where used for correlation)

3.3 Health Checks

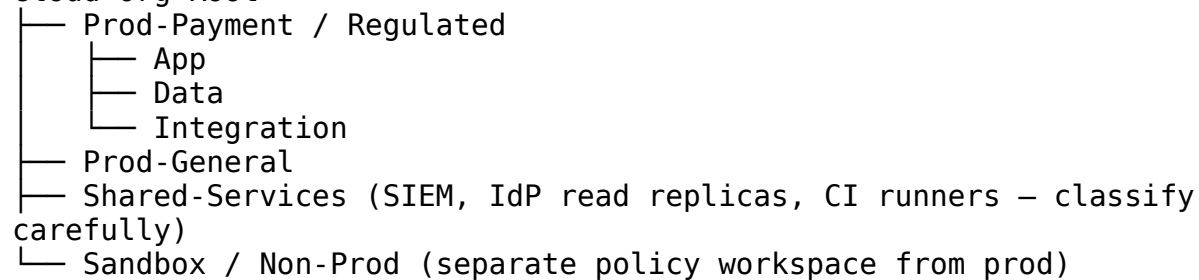
CSW UI → Manage → Agents / Connectors

- All production tier assets reporting
 - Version compliance with golden image standard (feeds CCC evidence)
-

4. Phase 2 — Scope, Zones, and Data-Flow Architecture (Days 5–14)

4.1 Recommended Logical Model (Maps to DSP / IVS)

Cloud-Org Root



4.2 Labeling for STAR / CCM Traceability

Label	Example	Maps to evidence
ccm_domain_focus	IVS, LOG, DSP	Control scoping notes in STAR file
data_class	pci, pii, confidential, public	DSP segmentation narratives
pci_in_scope	true/false	When PCI DSS overlays apply
star_service	SVC-042	STAR service catalogue reference

5. Phase 3 — Visibility, ADM Baseline, and TVM (Days 10–35)

5.1 Application Dependency Mapping (AIS / DSP)

CSW UI → Investigate → Application Dependency Mapping

- Workspace: CCM-ADM-<BusinessService>-<Period>
- Scope: in-scope prod tiers for the STAR service
- Minimum duration: 14 days (capture batch / billing cycles)
- Capture process + user context for interface inventory (AIS)

AIS-focused review prompts:

Question	CCM tie-in
Which binaries initiate egress to third-party APIs?	AIS — interface inventory
Which internal services accept unauthenticated connections?	AIS / IAM
Are admin interfaces exposed laterally beyond operator subnets?	IVS / IAM

5.2 TVM — Exposure and Reachability (TVM)

CSW UI → Investigate → Vulnerability Report

- Filter: internet-adjacent AND path to regulated data tier in ADM
- Export: CVE list with workload ID, CVSS, fix status linkage

Use exports as **inputs** to CCM TVM control narratives, not as the sole source of truth for patch SLAs.

5.3 Baseline Snapshots for BCR / CCC Validation

- Export ADM graph and policy workspace after each **approved release** → store as **configuration baseline artifacts** (CCC).
 - After DR tests, compare connectivity patterns (counts, critical paths) against pre-event baseline → attach summary to BCR test report.
-

6. Phase 4 — Policy Design — IVS, IAM, DSP (Days 25–45)

6.1 Policy Workspace Structure

CSW UI → Defend → Segmentation

- Workspace: STAR-<Service>-Prod-Enforce
- Scope labels: data_class in (pci, pii, confidential)
- Import ADM recommendations
- Rule metadata: owner, ticket, review_date, ccm_control_reference (free text field if available)

6.2 IVS-09 (Network Segmentation / Security) — Pattern

CCM **IVS-09** objectives center on network segmentation appropriate to sensitivity. At the workload layer:

```
# Illustrative policy pattern – replace with ADM-derived peers
DEFAULT: DENY east-west not explicitly approved within Prod-Payment
ALLOW:   Payment-App → Payment-DB [least-privilege ports only]
ALLOW:   Payment-App → Shared-KMS-Endpoint [443 – if architecture
uses cloud KMS]
DENY:     Prod-General → Prod-Payment (all ports) except documented
break-glass
LOG+ALERT: First-seen lateral connection inside Prod-Payment
```

6.3 IAM Integration (Technical Enforcement Dimension)

- Align CSW scopes with **enterprise identity segmentation** (e.g., admin SGs, PIM roles). CSW rules should reference **who is allowed to originate** admin flows (jump boxes) rather than opening broad management subnets.

6.4 DSP — Data Flow Boundaries

- Enforce **tier separation** (presentation / application / data).
 - Create **explicit rules** for backup, replication, and SIEM egress so data movement is **expected and logged**.
-

7. Phase 5 — Enforcement Progression and Change Discipline

Stage	Objective	CCC / GRC note
Simulation	Tune alerts; document false positives	Link to change tickets
Phased enforcement	Start with identifiable bad paths (open internet from data tier)	Record CAB approvals
Full enforcement	Default deny + signed allow-list	Control owner sign-off stored with STAR evidence

Change detection (CCC): any net-new listening port or unexpected peer cluster observed post-release should trigger **ADM diff review** before permanent allow-list update.

8. Phase 6 — LOG / SEF: Monitoring, SIEM, and Forensics

8.1 LOG Domain — Telemetry to SIEM

CSW UI → Settings / Integrations (per product)
→ Configure syslog / webhook / vendor connector to SIEM
→ Map severity to SOC playbooks

Retain mapping documentation: field list, filter rules, retention period, and sampling methodology (supports **A&A** evidence requests).

8.2 SEF — Incident Evidence

CSW UI → Investigate → Flow Search + Process Search
→ Narrow by workload scope label `star_service=<id>`
→ Export incident package with UTC timestamps and policy action

Pair CSW exports with CSP CloudTrail / Azure Activity Log where authorities require **control-plane** and **data-plane** correlation.

9. Domain-to-Control Mapping Table (Summary)

The CSA CCM enumerates objectives with codes (e.g., **AIS-01**, **IVS-09**). Exact numbering should be cited from your official **CCM v4** spreadsheet or STAR tool export. This table summarizes **domain-level** expectations versus CSW.

CCM domain	Representative objectives (examples)	CSW capability	Evidence examples
AIS	Secure SDLC interfaces; API protections	ADM dependency map; deny unexpected service bindings	ADM export; list of approved listeners per tier
BCR	Resilience testing; recovery procedures	Pre/post DR ADM/policy diff; availability of telemetry during tests	Test report attachment with connectivity baselines
CCC	Change / config management	Drift detection; inventory deltas	Quarterly diff report; CAB ticket linkage
DSP	Data classification handling; residency patterns (as applicable)	Segmentation between classes; monitored egress	Policy workspace + DSP data-flow diagram

CCM domain	Representative objectives (examples)	CSW capability	Evidence examples
GRC	Metrics, improvement	Dashboards of policy violations, sensor coverage %	Monthly KPI export to GRC tool
HRS	Personnel practices	<i>Not applicable to CSW</i>	Narrative stating HR controls separate
IAM	Access enforcement	Identity-aware segmentation; admin path controls	Jump-host-only allow rules with logs
IVS	Host / virtualization / network security incl. IVS-09	Micro-segmentation; cloud VM inventory	Enforcement report by VPC/VNet
LOG	Central logging & monitoring	Flow/process telemetry; SIEM feed health	Connector uptime; sample events
SEF	Incident handling & forensics	Timeline reconstruction; process trees	Incident export bundle
TVM	Vuln management	CVE + exposure context	Risk-ranked export

10. Boundaries — What CSW Does **Not** Cover for CCM

- **HRS** end-to-end (background checks, training completion records).
- **Purely contractual / legal** STAR attestations without technical instrumentation.
- **Cloud control plane** configuration (unless reported via complementary integrations): IAM role design, KMS policy, bucket ACLs—CSW informs workload behavior but does not replace CSP IAM review.
- **Endpoint mobility / UEM** UES fleets unless those endpoints carry CSW agents and are in scope.
- **Customer responsibilities** mis-labeled as provider responsibilities under shared responsibility—always map CCM rows to the correct party before claiming implementation.

11. Common Pitfalls

Pitfall	Mitigation
STAR scope drift — workloads appear outside labelled VPCs/VNets	Weekly inventory reconcile; enforce tag inheritance at subscription/project
CCM row claimed without shared-responsibility check	Mark customer vs. CSP for each objective; attach responsibility matrix
IVS policies only at cloud edge	Add east-west segmentation on critical tiers; document defense-in-depth
SIEM integration skipped	Treat LOG domain as failed until centralized retention is proven
Non-prod changes promoted without ADM diff	Re-baseline ADM after each release; CAB blocks rule changes without diff
Over-alerting → SOC disables feeds	Tune in simulation; severity mapping before enforcement

12. Audit Preparation and Evidence Export (STAR / Customer Audit)

12.1 Suggested Evidence Package by Domain Focus

CCM domain focus	Include in package
IVS / IAM / DSP	Policy PDF or JSON export + ADM snapshot + scope inventory CSV
LOG	SIEM schema mapping + 90-day retention attestation + sample alerts
TVM	Vulnerability export + remediation ticket cross-reference
AIS	Interface inventory derived from ADM clusters + pen test linkage if performed
GRC	Coverage metrics (% agents healthy, % workloads in-scope) trend line

12.2 Automation Snippet (Inventory Pull)

```
#!/usr/bin/env bash
set -euo pipefail
# Illustrative – substitute your approved API client / secrets manager paths.
OUTDIR="./ccm_evidence_$(date -u +%Y%m%d)"
mkdir -p "${OUTDIR}"
# Example placeholders:
# csw-cli inventory export --scope CCM-STAR-SVC042 --output "${OUTDIR}/inventory.csv"
# csw-cli policy export --workspace STAR-SVC042-PROD --output "$
```

```
{OUTDIR}/policy.json"  
echo "Package ${OUTDIR} and upload to secure evidence store per GRC  
policy."
```

Appendix A — CCM v4 and Other Frameworks

CSA publishes **Consensus Assessment Initiative Questionnaire (CAIQ)** and mapping matrices correlating CCM to **ISO/IEC 27001**, **NIST**, **PCI DSS**, and others. Use those mappings to avoid duplicate work: a single CSW flow-enforcement narrative may satisfy overlapping rows **when** scope and responsibilities match.

Appendix B — Related Reference Designs

- [NIST SP 800-53 Rev. 5](#)
 - [NIST SP 800-171 Rev. 3](#)
 - [ISO/IEC 27001:2022](#)
 - [PCI DSS v4](#)
 - [SOC 2](#)
 - [NIST SP 800-207 \(Zero Trust\)](#)
-

Replace customer-specific identifiers before distribution. STAR submissions and CCM interpretations remain the responsibility of the assessed organization and its auditors.